Bilag 9.i Leverandørens løsningsbeskrivelse

Dynamisk indkøbssystem 02.19 Fagsystemer (2024)

Kontrakt om levering af ESDH løsning til Danmarks Nationalbank

SKI0219.2503.0030

Version 1.1

Staten og Kommunernes Indkøbsservice A/S
Montagehallen | Pakkerivej 6, 2500 Valby
Telefon +45 33 42 70 00 | CVR 17472437

Indhold

1 Indledning 3
2 Særlige sikkerhedsforanstaltninger 4
3 Leverandørens efterlevelse af CIS Controls Cloud Companion Guide 6
4 Særligt vedrørende Logning 8

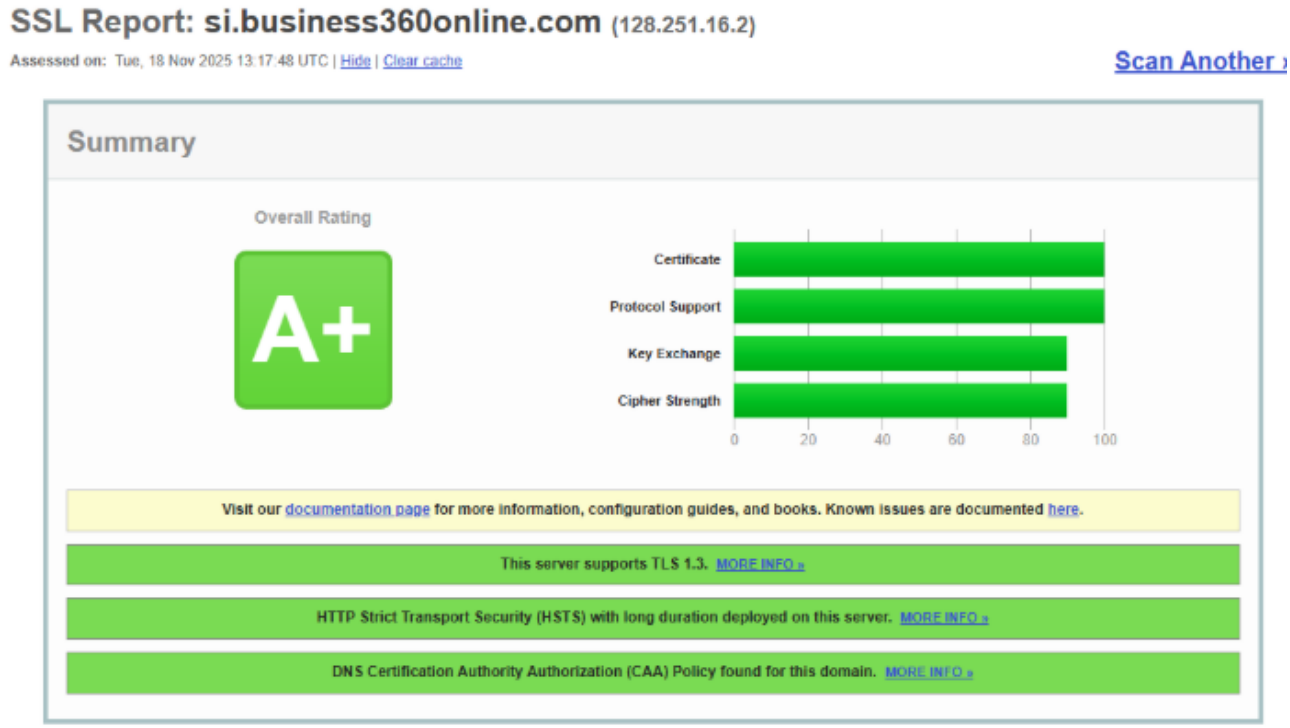
1 Indledning

Leverandøren har i nærværende bilag beskrevet de forhold, som Kunden har efterspurgt vedrørende sikkerhed.

2 Særlige sikkerhedsforanstaltninger

Certifikater og CA-verifikation

Leverandøren anvender en anerkendt Certificate Authority (**DigiCert**) til udstedelse af certifikater. Selvom løsningen benytter standard domain-certifikater, har Tietoevry gennemgået samme omfattende verifikationsproces som ved EV-certifikater, herunder dokumentation af organisationens juridiske, fysiske og operationelle eksistens. Dette sikrer høj troværdighed og compliance med internationale sikkerhedsstandarder.



Beskyttelse mod DDoS-angreb

Domestic Cloud-miljøet er sikret med avancerede netværksbeskyttelsesmekanismer, herunder:

- IDS/IPS-systemer til detektion og blokering af angreb
- Rate-limiting og trafikfiltrering på netværksniveau
- Firewall-regler og segmentering for at minimere angrebsflader

Mitigerende foranstaltninger kan konfigureres efter kundens behov og aktiveres ved identificerede trusler.

IPSec og dedikeret linje

Tietoevry understøtter etablering af **IPSec-beskyttede, krypterede linjer** til Domestic Cloud. Dette sikrer:

- Krypteret kommunikation mellem kundens netværk og platformen
- Minimal risiko for aflytning eller manipulation af data under transport

Overvågning, rapportering og kommunikation under angreb

Domestic Cloud overvåges af Tietoevry's **Security Operations Center (SOC)**, som er aktiv **24/7** og baseret i et svensk datacenter. SOC-funktionerne omfatter:

- **Realtidsdetektion og alarmering** ved cyberangreb, inkl. DDoS
- **Løbende rapportering til kunden eller dennes repræsentant** under angreb, inkl.:
  - Mål for angrebet
  - Angrebstype
  - Varighed og intensitet (requests/sec, packets/sec, bytes/sec)
  - Igangsatte modforanstaltninger
- Levering af indikatorer, typisk en 'Top 100'-liste over IP-adresser fra angriberens infrastruktur

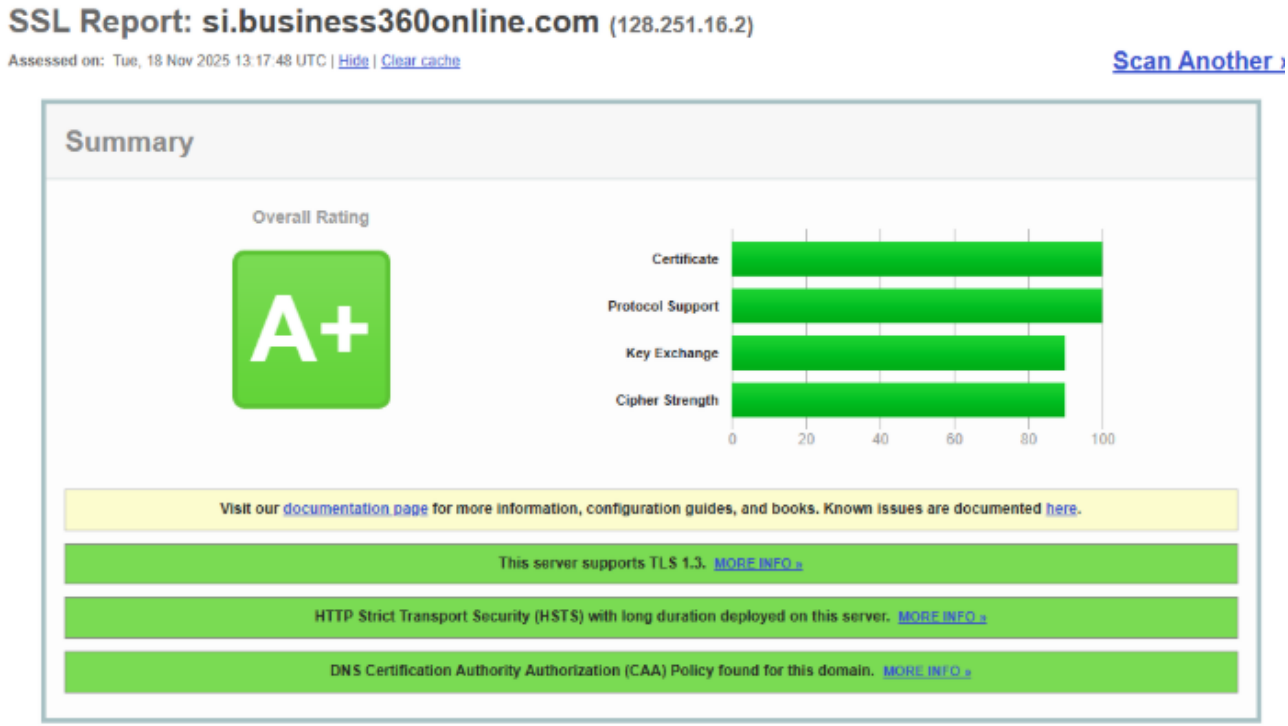
Disse oplysninger deles med kundens repræsentant og samarbejdsorganisationens kontaktperson jf. bilag 1. Formålet er at orientere forretningen og ledelsen, samt informere relevante eksterne partnere og leverandører. Data anvendes desuden til evaluering af løsningens robusthed og forbedringspotentiale.

Compliance og standarder

Domestic Cloud er designet til at opfylde kravene i:

- **ISO 27001**
- **GDPR**
- Tietoevry's interne sikkerhedsprocedurer for hændelseshåndtering og rapportering

Eksempel fra 'https://www.ssllabs.com'



DDoS-angreb: Mitigerende foranstaltninger kan opsættes og konfigureres hvis det ønskes. Der findes processor og rutiner for overvågning samt kommunikation til kunde, dette inkluderer også almindelige sikkerhedshændelser.

IPSec: IPSec er understøttet, og kan opsættes hvis det ønsker.

3 Leverandørens efterlevelse af CIS Controls Cloud Companion Guide

Tietoevry kan bekræfte, at **Public 360°-løsningen på Domestic Cloud er designet til at understøtte CIS Controls Cloud Companion Guide v.8.1**. Løsningen er baseret på en sikkerhedsarkitektur, der følger CIS-rammeværket og opretholder kravene i hele kontraktperioden.

Overensstemmelse med CIS CCCG v.8.1 – Konkrete eksempler

Følgende kontroller er implementeret:

- **Identitets- og adgangsstyring (CIS Control 6 & 16)**
  - Multi-Faktor Autentifikation (MFA) for alle administrative og brugeradgange
  - Rollebaseret adgang (RBAC) med princippet om mindst privilegium
  - Central styring af identiteter og adgangsrettigheder
- **Netværkssikkerhed (CIS Control 12)**
  - Segmentering af netværk og firewall-regler for at minimere angrebsflader
  - IDS/IPS-systemer til detektion og blokering af uautoriseret trafik
  - Krypteret kommunikation via IPSec-beskyttede linjer
- **Data Protection (CIS Control 3 & 13)**
  - Kryptering af data i transit (TLS 1.2+) og i hvile (AES-256)
  - Beskyttelse af database og arkiv med stærke krypteringsnøgler
  - Kontroller for dataintegritet og backup-strategier
- **Sårbarhedsstyring og patching (CIS Control 7)**
  - Kontinuerlig scanning for sårbarheder
  - Regelmæssige sikkerhedsopdateringer og patch management
- **Logning og overvågning (CIS Control 8 & 17)**
  - Central logning af alle sikkerhedshændelser
  - 24/7 overvågning via Tietoevry's SOC
  - Hændelseshåndtering med realtidsalarmer og eskalering
- **Malwarebeskyttelse og indtrængningsdetektion (CIS Control 10)**
  - Antivirus og antimalware på alle servere
  - IDS/IPS til forebyggelse af angreb

Fravigelser

Eventuelle fravigelser fra CIS CCCG er **ikke væsentlige** og vedrører kun områder, hvor alternative kontroller giver tilsvarende eller højere sikkerhedsniveau.

Forpligtelser i kontraktperioden

- Alle tilbudte kontroller opretholdes i hele kontraktperioden.
- Ved nye versioner af CIS CCCG vil Tietoevry:
  - Analysere ændringerne
  - Dokumentere løsningens overensstemmelse med den nye version
  - Gøre dokumentationen tilgængelig for kunden uden ekstra omkostninger
- Hvis opfyldelsesgraden øges, implementeres forbedringer uden ekstra omkostninger for kunden.

4 Særligt vedrørende Logning

Tietoevry kan bekræfte, at Public 360°-løsningen på **Domestic Cloud** er designet i overensstemmelse med kravene i **ISO 27001** og **CIS Controls Cloud Companion Guide v.8.1**, herunder krav til indsamling, opbevaring og håndtering af logs. Løsningen understøtter en omfattende logningsstrategi, som sikrer sporbarhed, hændelseshåndtering og compliance.

Logningsprincipper og omfang

- **Central logning:** Alle relevante systemhændelser, applikationslogs og sikkerhedsrelaterede events indsamles og opbevares i en central logningsinfrastruktur i Domestic Cloud.
- **Omfattede events:**
  - **Integrationer:** API-kald og integrationspunkter logges med tidsstempel, kilde og status.
  - **Brugerhandlinger:** Direkte og indirekte brugeraktiviteter, herunder login, dataændringer og transaktioner.
  - **Privilegeret adgang:** Alle administrative handlinger og konfigurationsændringer logges med detaljer om bruger, tidspunkt og udført handling.
- **Retention og beskyttelse:** Logs opbevares i henhold til ISO 27001-krav og beskyttes mod uautoriseret adgang.

Overvågning og hændelseshåndtering

- Logs anvendes aktivt i **Tietoevry's SOC**, som overvåger Domestic Cloud 24/7
- SOC analyserer logdata for anomalier og sikkerhedshændelser og eskalerer kritiske events i realtid.
- Alle hændelser dokumenteres og indgår i compliance-rapporter.

Integration med kundens logopsamlingsplatform

- Direkte integration til Microsoft Azure Log Analytics Workspace er ikke understøttet for Domestic Cloud.

Compliance og forpligtelser

- Vores organisation er ISO 27001-certificeret, og løsningen er udviklet og forvaltet i overensstemmelse med de certificerede informationssikkerhedsprocesser. Dette sikrer, at løsningen efterlever de samme styringsprincipper, risikohåndteringsmekanismer og sikkerhedskontroller, som er verificeret gennem vores ISO 27001-revisioner. (Seneste revision: oktober 2025)

- Logningskontroller er i overensstemmelse med CIS CCCG v.8.1, herunder:
    - **Control 8:** Audit Log Management
    - **Control 17:** Incident Response Management
- Eventuelle fravigelser er ikke væsentlige
- Tietoevry forpligter sig til at opretholde og forbedre logningsfunktionaliteten i hele kontraktperioden.